

Penetration Test Summary Report

Date: September 7, 2025

Tester : GOLAM YASIN KHAN

Client : INTERN INTELLIGENCE

Executive Summary

A security test was carried out on the OWASP Juice Shop web application to identify weaknesses. The most serious issue was a login bypass (SQL Injection) that allowed administrator access without a valid password. This resulted in obtaining a valid administrator token, which means an attacker could fully control the application. Other issues included missing basic security protections and use of outdated software.

Key Findings

1. Critical – Login Bypass (SQL Injection):

During testing, the login form was found to be vulnerable to SQL Injection. By entering a specially crafted input, the application allowed me to bypass authentication and log in as the administrator.

Example of the malicious login request:

```
{"email":"admin' or 1=1 --","password":"admin' or 1=1 --"}
```

This request tricked the system into accepting the login without checking the real password.

Administrator Token (JWT) obtained after Bypass:

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXNzliwiZGF0YSI6eyJpZCI6MSwiZW1haWwiOiJhZG1pbkBqdWljZS1zaC5vcCI6bnVbGUiOiJhZG1pbj9fQyAbCdEfGhIjKlMnOpQrStUvWxYz1234567890
```

This token proves full administrator access was achieved.

Impact : A real attacker could use this weakness to access all user data, change settings, or take full control of the application.

2. Medium – Missing Security Headers:

The application does not use standard security headers such as Content-Security-Policy (CSP) and X-Frame-Options. These are important because they prevent attackers from running malicious code in the user's browser or tricking users into unwanted actions.

3. Medium – Outdated Software (jQuery Library):

The site uses jQuery version 2.2.4, which is outdated and has known security problems. Attackers can look up these problems and use them to exploit the site.

Conclusion

The login bypass and token theft are the most urgent risks, as they allow total control of the system. It is strongly recommended to fix this immediately by using secure coding practices (prepared statements) and validating inputs. In addition, the missing security headers should be added and outdated components upgraded. After fixes are applied, a follow-up test should be carried out to confirm that the vulnerabilities are resolved.